ОТЧЁТ О СООТВЕТСТВИИ ТРЕБОВАНИЯМ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Система: КТК ЭЛОУ-АВ Дата оценки: 2026-08-12

1. ЦЕЛЬ И ОБЪЕКТ ОЦЕНКИ

Цель: проверить соответствие реализации системы КТК ЭЛОУ-АВ базовым требованиям информационной безопасности для web-приложения с AI-функционалом.

Область оценки охватывает:

- аутентификацию и авторизацию (OIDC/OAuth2, JWT);
- ролевое разграничение доступа (RBAC) на уровне API;
- защиту входных данных (санитизация, anti-abuse);
- сетевые и HTTP-защиты (CORS, заголовки, rate limiting);
- управление секретами и конфигурационные риски;
- аудит действий пользователей;
- разделение окружений dev/prod.

Методология: статический анализ кода, динамические проверки API (postman/curl), обзор конфигураций деплоя.

2. СВОДНАЯ МАТРИЦА СООТВЕТСТВИЯ

N	**Требование ИБ**	**Статус**	**Уровень риска**	**Краткое подтверждение**
1	Аутентификация через OIDC/OAuth2 (prod)	Соответствует	Низкий	Backend — Resource Server с проверкой JWT; frontend — Authorization Code Flow
2	Проверка JWT-подписи по JWK (Keycloak)	Соответствует	Низкий	JwK endpoint настроен
3	Ролевое разграничение доступа к API	Соответствует	Низкий	Endpoint-правила в SecurityConfig.kt

4	Маппинг ролей Keycloak -> authorities	Соответствует	Низкий	Извлечение realm_access/resource_access
5	Защита AI-эндпоинта от prompt-injection/XSS	Соответствует	Средний	Санитизатор SupportSanitizer.kt
6	Rate limiting для AI-эндпоинта	Соответствует	Средний	Реализован AiRequestRateLimiter (окно/порог)
7	Ограничение размера входных данных (anti-abuse)	Соответствует	Средний	Проверка payload -> 413
8	Аудит действий пользователя	Соответствует	Низкий	Модель AuditRecord, логирование в контроллерах
9	CORS-ограничения	Соответствует (локальные источники)	Средний	allowed origins/methods заданы
10	Разделение dev/prod	Частично	Высокий	В prod JWT включена, в dev — отключена
11	Управление секретами в deploy	Частично	Высокий	CI использует secrets, но в docker-compose.local.yml есть открытый API-ключ
12	Защита от CSRF	Частично	Высокий (при cookie)	CSRF отключен в конфигурации

Итоговый статус: 9 из 12 требований закрыты полностью, 3 — с частичным соответствием, требующим доработки.

3. ДЕТАЛЬНЫЕ РЕЗУЛЬТАТЫ ПРОВЕРОК

3.1. Автоматизированные тесты (Unit / Integration)

- Backend security-тесты: пройдены успешно (100% прохождение).
- Проверка API в prod-профиле (localhost:8081):
    - GET /api/sessions без токена -> 401
    - GET /api/sessions с невалидным JWT -> 401
    - GET /api/sessions с валидным токеном instructor -> 200 OK
- HTTP-заголовки безопасности (наблюдаются в ответах):
    - X-Content-Type-Options: nosniff
    - X-Frame-Options: DENY
    - Cache-Control: no-cache, no-store, must-revalidate
    - Pragma: no-cache
    - Expires: 0

3.2. Статический анализ конфигураций

- OAuth2 Resource Server настроен корректно (application.yml).
- RBAC правила описаны декларативно, роли маппятся из JWT.
- Санитизация входных данных применяется к AI-запросам.
- Rate limit реализован на основе клиентского ключа.
- Аудит логирует как действия пользователя, так и системные события.

4. ВЫЯВЛЕННЫЕ РИСКИ И ОГРАНИЧЕНИЯ (с приоритетами)

N	Описание риска	Категория	Уровень	Компенсирующие меры / комментарий
1	Dev-профиль отключает авторизацию — это может привести к ложным результатам при ручном тестировании и случайному использованию dev-конфигурации на prod-подобных стендах.	Конфигурация	Критичный	Разработчики должны явно указывать spring.profiles.active=prod при ИБ-тестах. Рекомендуется добавить автоматическую проверку профиля в CI.
2	Секрет (API-ключ) хранится в открытом виде в docker-compose.local.yml —	Секреты	Критичный	В CI секреты передаются через переменные. Локальный композ

	риск утечки и несанкционированного доступа к внешнему AI-сервису.			должен использовать переменные окружения, а не фиксированные значения.
3	HTTPS не принудительно включён на уровне приложения — возможна передача токенов по HTTP при неправильной настройке внешнего контура.	Транспорт	Высокий	Компенсация: TLS-termination на ingress + HSTS. Необходимо задокументировать обязательное требование.
4	CSRF отключён — если в будущем будет использоваться cookie-based сессия, возникнет уязвимость.	Архитектура	Средний	Текущая схема (JWT в Bearer-заголовке) не подвержена CSRF. Риск актуален только при изменении механизма аутентификации.

5. РЕКОМЕНДАЦИИ (дорожная карта усиления)

Действие	**Ответственный**	**Срок**	**Приоритет**
1. Перенести все секреты из репозитория в Secret Manager / CI-variables; заменить в docker-compose.local.yml на ${} ссылки	DevOps / Dev	1 неделя	Критично
2. Добавить в CI отдельный smoke-тест безопасности, который запускается ТОЛЬКО в prod-профиле и проверяет: 401/403, ролевую матрицу, наличие защитных заголовков	Dev + QA	2 недели	Критично
3. Зафиксировать политику: все ИБ-проверки доступа выполнять	Team Lead	1 неделя	Высокий

исключительно в prod-профиле (документировать в runbook)			
4. Создать централизованный документ "Обязательные требования к транспортной защите" (TLS 1.2+, HSTS) и включить его в процесс развертывания	ИБ-офис	1 месяц	Высокий
5. Подготовить формальный чек-лист ИБ (с владельцами и периодичностью ревизии) на основе данной матрицы	ИБ-офис	2 месяца	Средний
6. Провести повторную оценку после устранения критических и высоких рисков (запланировать на 2026-09-01)	ИБ-аудитор	согласно графику	Высокий

6. ИТОГОВОЕ ЗАКЛЮЧЕНИЕ

Система КТК ЭЛОУ-АВ в prod-профиле демонстрирует БАЗОВОЕ СООТВЕТСТВИЕ требованиям ИБ для web-API с AI-функционалом:

- аутентификация и авторизация работают штатно;
- ролевая модель применяется корректно;
- входные данные санитизируются, действует rate limit и контроль размера;
- аудит ведётся;
- защитные HTTP-заголовки присутствуют.

Однако выявлены ТРИ ЗОНЫ ЧАСТИЧНОГО СООТВЕТСТВИЯ, которые несут КРИТИЧЕСКИЕ И ВЫСОКИЕ РИСКИ:

1. Смешение dev/prod (риск ошибочного тестирования).
2. Хранение секретов в открытом виде в локальном композе.
3. Отсутствие формализованных требований к TLS и CSRF-модели.

Решение: документ считать РАБОЧЕЙ ОЦЕНКОЙ, а не сертификатом.